



BUSINESS EXPANSION PROPOSAL • ALL SUITE MODULES • DRAFT V0.1

Radiant Medical Physics Consulting — Business Expansion Proposal

Subject: Productization, distribution, and storage strategy for the Quik suite **Scope:** All modules surfaced at app.radiant-mpc.com (QuikQA, QuikFlow, QuikCalc, QuikBolus, QuikCare, QuikDose, QuikLog, QuikPay, QuikRAM, QuikRef, QuikScript, QuikShare, QuikShield, QuikXpense, QuikBusiness) plus any future modules added to the suite. **Status:** Draft v0.1 **Author:** Radiant Medical Physics Consulting LLC **Date:** 2026-05-24

1. Executive summary

Radiant currently operates a hybrid surface: a marketing site (radiant-mpc.com), an authenticated app shell (app.radiant-mpc.com) running on Cloudflare Workers + D1, and a portfolio of desktop Python applications (the Quik suite) sitting locally. Of those Quik modules, only **QuikFlow** is presently embedded in the app shell; the rest are desktop-only.

The strategic question this proposal addresses is: **how should Radiant package, sell, and support the full Quik suite as it grows beyond a handful of pilot clients?**

The recommendation is a **four-phase hybrid strategy**:

1. **Phase 1 (0–60 days):** Reposition app.radiant-mpc.com as a *trial sandbox and demo surface*. Codify expectations in copy. Keep current browser-only storage. Cost: ~\$0 incremental.
2. **Phase 2 (60–180 days):** Stand up a **desktop production channel** — PyInstaller-built signed Windows installers for each licensed module, distributed via the existing license manager. Each installer runs fully offline, stores data on the clinic's local share, and phones home to the existing [/api/revoked](#) endpoint at startup for license enforcement. This becomes the *commercial* delivery channel for all modules.
3. **Phase 3 (6–18 months, demand-driven):** Layer an **optional non-PHI cloud storage tier** on top of the desktop apps for clients who want centralized backup, multi-site access, or audit trails. Built natively on Cloudflare (D1 + R2). Sold as an add-on subscription. Triggered only by paying-customer demand — never built speculatively.
4. **Phase 4 (24–36 months, demand-driven):** Stand up a **separate HIPAA-compliant cloud tier** for customers whose use case requires PHI handling. Built on Aptible (initially) or AWS (at scale), with full BAA coverage, encryption, audit logging, and compliance program. Premium-priced as a distinct SKU. **Do not enter this market with fewer than ~10 committed customers** — the fixed compliance overhead makes small-scale operation structurally unprofitable.

This sequencing protects cash flow, keeps Radiant out of the data-custody business until a customer pays for it, and reuses every piece of infrastructure already built (license manager, revocation, portal auth, installer scaffolding under `C:\Users\toddb\Downloads\radiant_quikqa*_patch\`).

2. Current state assessment

2.1 Infrastructure

COMPONENT	LOCATION	STATUS
Marketing site	<code>radiant-mpc.com</code> (GitHub Pages → CF Worker)	Production
App shell	<code>app.radiant-mpc.com</code> (CF Worker <code>worker/index.js</code>)	Production
License manager	<code>/admin/*</code> + D1 <code>licenses</code> table	Production
Client portal	<code>/portal/*</code> + D1 <code>clients</code> , <code>portal_sessions</code>	Production
Public revocation endpoint	<code>/api/revoked</code>	Production
Embedded apps	<code>/app/apps/quikflow/</code>	QuikFlow only
Desktop apps	<code>C:\Radiant_Quik*\</code> (Python source)	All other modules
PyInstaller installer scaffolding	<code>C:\Users\toddb\Downloads\radiant_quikqa*_patch\</code>	Patch-tested through v0.3.4

2.2 Data persistence today

The only embedded module (QuikFlow) persists user data via `localStorage` (form state, custom payment methods, custom income categories) and `IndexedDB` (receipt scans as blobs). All data lives in **one browser, on one device, for one user**. There is no server-side storage table for end-user work product in `schema.sql` — only license/client/session/admin tables.

2.3 Gaps relative to the suite's clinical use case

Every Quik module that supports a clinical workflow needs at least one of the following, and the current setup provides none of them in the browser channel:

- **Daily QA**: rapid entry, prior-day recall, trend plotting across weeks/months.
- **Monthly / annual QA**: structured forms, attachments (machine logs, scanned worksheets, screenshots), formal archive that's retrievable years later for accreditation surveys (ACR, ACRO, state inspections).
- **Multi-physicist access** at a single site (Physicist A's saved entries must be visible to Physicist B).
- **Multi-site access** for consulting groups covering multiple clinics.
- **Backup and disaster recovery** that survives a laptop replacement or a browser cache wipe.
- **Audit trail** showing who recorded what and when.

For a paying clinical customer, every one of those gaps is a blocker.

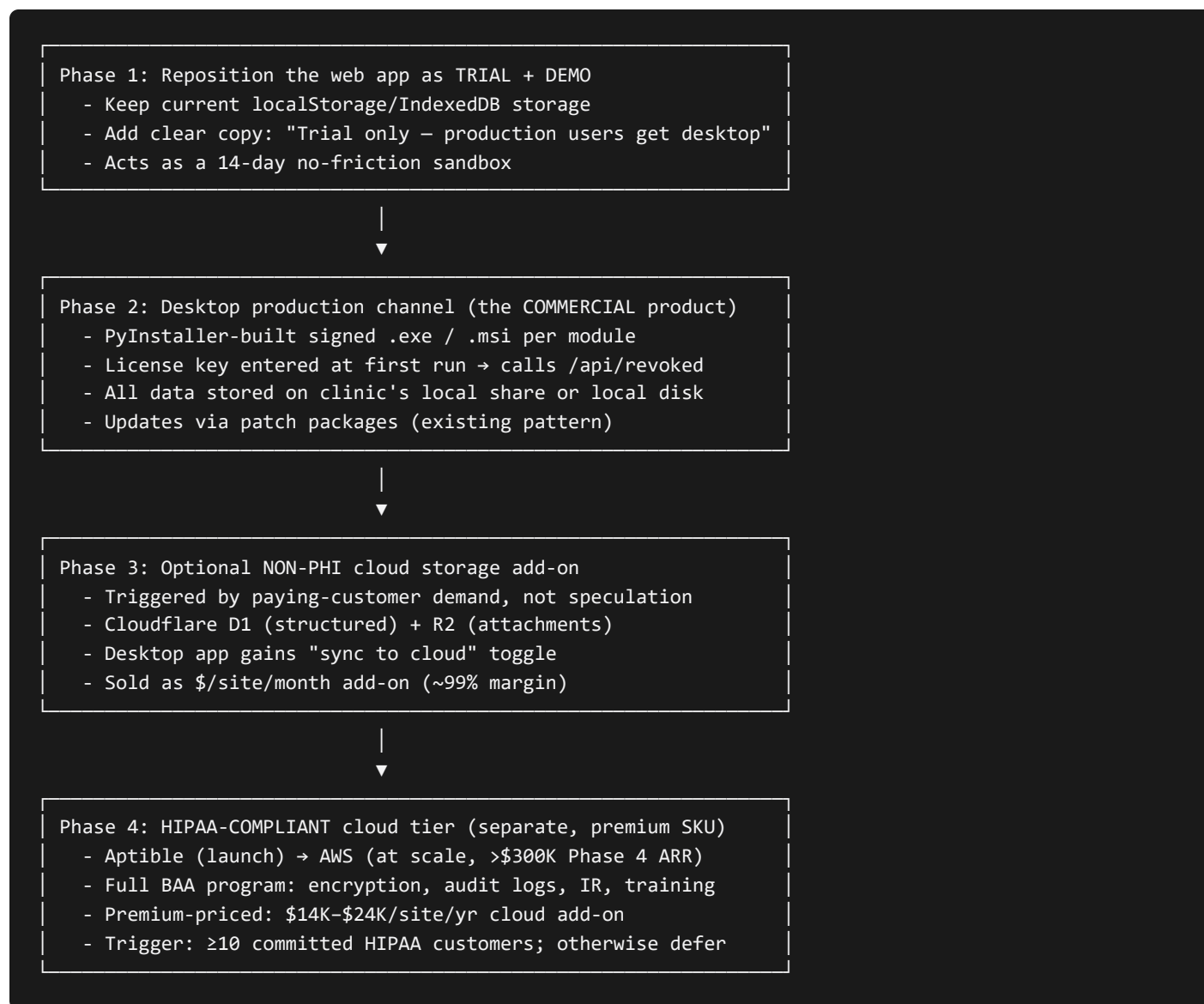
3. Strategic recommendation: hybrid, desktop-first, cloud-optional

3.1 Why this shape

The medical-physics software market has stable, observable characteristics:

- **Customers are conservative.** Incumbents (PIPSpro, RIT, Doselab Pro, SunCheck) all ship desktop installers. Cloud-only is an outlier.
- **Hospital IT is procurement-hostile to cloud.** BAAs, VLAN reachability, data-residency questions, security questionnaires — every one of these adds 30–90 days to a deal.
- **Clinical sites have unreliable internet.** Treatment vaults and bunkers are routinely on isolated VLANs or in basements where Wi-Fi is poor. Software that requires connectivity loses deals.
- **QA data is not typically PHI.** Machine output factors, flatness/symmetry, dosimetric checks — there are no patient identifiers in standard physics QA. This is important because it means Radiant does **not** need a HIPAA BAA to handle QA data, which keeps cloud options open.
- **Desktop delivery aligns with how physicists already work** — they save reports to a network share, attach PDFs to email, archive into a `\\fileserver\physics\` tree. Software that respects that workflow wins.

3.2 The four-phase plan



4. Phase 1 — Reposition the web app (0–60 days)

4.1 What changes

- Add a persistent banner / footer on every `app.radiant-mpc.com` page: *"Trial sandbox — your data is stored in this browser only. For permanent records, contact Radiant for a licensed desktop install."*
- Migrate the other QuikFlow-style standalone apps that are already feasible as single-file HTML (QuikCalc, QuikRef, QuikScript, QuikDose calculator, QuikRAM) into `/app/apps/<name>/` as demos. Treat each as a self-contained tile from the launcher.
- Build a simple "Request a trial" CTA on each module page that issues a 14-day license via the existing `/admin/api/licenses` POST endpoint.

4.2 Cost

- **Zero hosting cost increase.** Cloudflare Workers free tier (100K requests/day) and D1 free tier are already adequate.
- **Dev time:** ~1–2 weeks to migrate the simpler modules into the launcher and write the trial-request flow.

4.3 Pros

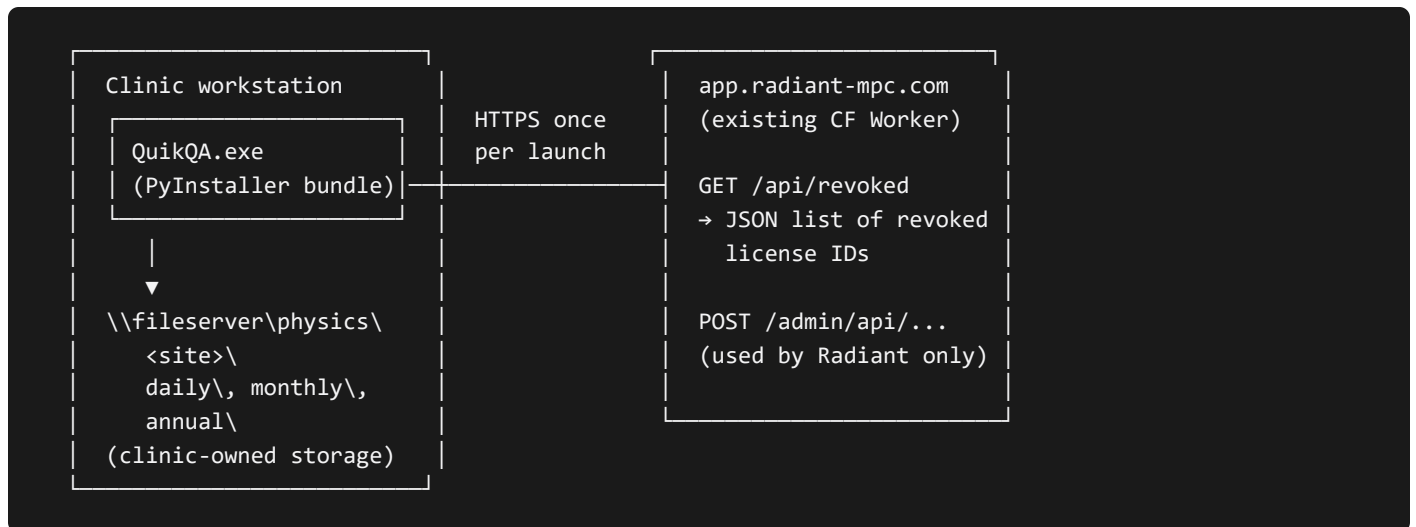
- Sales asset. Prospects can click "Try QuikQA" and have something in their browser in 10 seconds.
- Zero data liability — by design, nothing leaves the browser.
- Validates which modules attract the most clicks → informs Phase 2 priority order.
- Reuses 100% of existing infrastructure.

4.4 Cons

- Some prospects will assume the web version *is* the product and bounce when they hear there's a separate desktop install. Mitigated by clear copy and a one-click "send me the installer" flow.
- Browsers occasionally clear `localStorage` (Safari's 7-day ITP cap, incognito mode, "clear browsing data" clicks). Trial users may lose work mid-trial. Mitigated by an "export to JSON" button on every module and by keeping trials short (14 days).

5. Phase 2 — Desktop production channel (60–180 days)

5.1 Architecture



5.2 Procedural rollout

1. **Standardize the bundle layout.** Adopt the existing `radiant_core` / `radiant_gui` split already in the v0.3.4 patches as the canonical structure for every module.
2. **Per-module signed installer.** Use PyInstaller → Inno Setup → optional Authenticode code-signing certificate (~\$200–\$400/year through a reseller; meaningful trust signal for hospital IT).

3. **License entry on first launch.** The user pastes a license key Radiant emails them. The app validates the key's signature locally (using the existing license-core HMAC / Ed25519 pattern in `worker/license-core.js`), then makes one HTTPS GET to `/api/revoked` and refuses if the key ID appears. Cache the revocation list for 24h; on offline launch, allow if cached list is < 7 days old.
4. **Data storage:** at first launch, prompt the user to choose a storage root — defaults to `%LOCALAPPDATA%\Radiant\<module>\` but the customer can point it at a network share (`\\fileserver\physics\<site>\`). All daily/monthly/annual records, attachments, and exports go under that root.
5. **Update channel.** Continue the existing patch-zip pattern (`radiant_quikqa_v0.X.Y_patch\`). Add an in-app "check for updates" that calls a new endpoint `/api/version/<module>` returning the current version + a signed download URL.
6. **Per-module rollout order.** Recommend prioritizing by complexity × revenue potential: **QuikQA first** (most clinically demanded; daily/monthly/annual structure is the canonical workflow), then **QuikCalc**, **QuikBolus**, **QuikDose**, **QuikRAM**, **QuikShield**, **QuikScript**, **QuikRef**, **QuikLog**, **QuikCare**, **QuikShare**, **QuikPay**, **QuikXpense**, **QuikBusiness**, **QuikFlow**.

5.3 Cost

ITEM	ONE-TIME	RECURRING
Code-signing certificate (OV)	—	~\$300/yr
PyInstaller / Inno Setup / NSIS tooling	\$0	\$0
Existing CF Workers/D1 (license + revocation)	\$0	\$0–\$5/mo
Dev time per module (Phase 2 packaging)	1–3 weeks	—
Total at 15 modules packaged	~30–40 weeks dev	<\$500/yr ops

5.4 Pros — detailed

- **Hospital IT acceptance is the highest of any option.** No firewall holes, no BAAs, no security questionnaires beyond the standard "is your installer signed?" question.
- **Zero data liability.** Customer data never traverses Radiant's infrastructure. If a clinic is breached, Radiant is not in the blast radius.
- **Offline-capable.** Works in shielded vaults, on isolated VLANs, in basements.
- **Familiar form factor.** Identical to how PIPSpro/RIT/Doselab/SunCheck are delivered. Procurement knows how to buy this.
- **License enforcement already built.** The `/api/revoked` endpoint exists; the signing logic exists; the admin issue/revoke UI exists.
- **No per-user scaling cost.** Adding the 200th clinic costs the same as adding the 2nd (a license row in D1).
- **Predictable customer pricing.** Sell perpetual + maintenance, or annual subscription — both are well-understood in clinical software.
- **No hosting cost growth.** Cloudflare free tier continues to suffice; the heavy data lives at the customer's site.

5.5 Cons — detailed

- **Update friction.** Pushing a fix to 50 clinics means 50 patches need to be installed. Mitigated by the auto-update channel, but some sites lock down installers and need IT intervention.
 - **Blind to usage.** Radiant can't see telemetry unless it's built in explicitly. No "20% of users are stuck on the dose-rate screen" insights without phone-home telemetry, which is its own ethical/contractual question in clinical settings.
 - **Support is harder.** "Send me your log file" instead of "I can see the error in the dashboard." Mitigated by building a one-click "export support bundle" feature.
 - **License revocation has a lag.** If a customer goes 7+ days offline, the cached revocation list is stale. A determined ex-customer could keep using the software offline for weeks. This is acceptable — every desktop competitor has the same property and clinical customers don't try to pirate.
 - **Per-platform builds.** Windows is dominant in clinical physics (TPS workstations are Windows). macOS is rare; Linux is rarer still. Recommend Windows-only Phase 2; revisit if a customer specifically demands Mac.
 - **First-install friction.** Some hospital IT groups require packaging into SCCM/Intune for distribution. Mitigated by shipping an MSI alongside the EXE installer.
 - **No multi-site rollup.** A consulting group with 5 sites can't see all their data in one place. **This is the gap Phase 3 fills.**
-

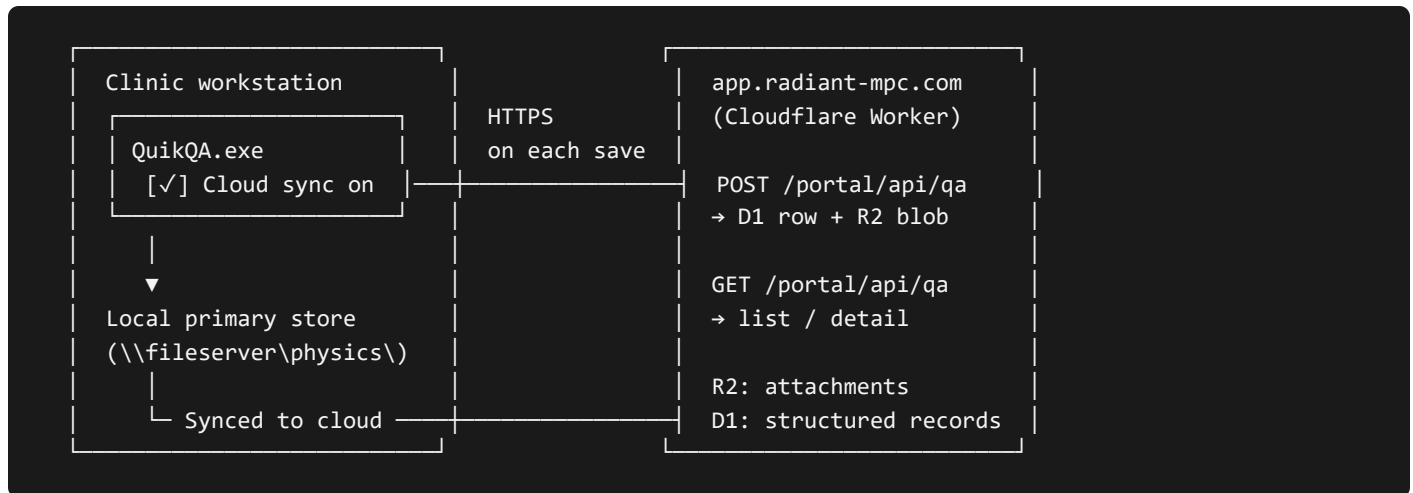
6. Phase 3 — Optional cloud storage add-on (6–18 months, demand-driven)

6.1 Trigger condition

Do not build Phase 3 until at least two paying customers ask for it. Likely shape of the ask: a consulting group covering 3+ sites wants a single login that aggregates QuikQA data, or a single site wants off-site backup of their annual QA archive.

Building cloud capability speculatively is the most expensive mistake on this roadmap. It adds compliance scope, security scope, and ongoing ops burden — none of which pay for themselves without customer demand.

6.2 Architecture



Key design choices:

- **Local-first, cloud-optional.** The desktop app's authoritative store stays local. Cloud is a *replica* and a *cross-site index*. If cloud is unreachable, the app keeps working; sync resumes when connectivity returns.
- **Per-tenant isolation.** Every D1 row carries `client_id` and `location_id`. Every R2 object key is prefixed `clients/<client_id>/<module>/...`. The Worker enforces tenant scoping on every API call (the pattern in `worker/clients.js` already exists).
- **Conflict resolution.** Last-write-wins on individual records, with a "version history" view in the web UI so nothing is truly lost. Avoid CRDTs — overkill for QA records that are rarely edited concurrently.
- **No PHI by policy.** Document that the cloud add-on is for QA data (machine metrology) only. Customers who want to attach patient-identified scans are turned away or directed to a future BAA-covered tier.

6.3 Procedural rollout

1. **Customer discovery.** Have 3+ concrete conversations confirming the demand and the willingness-to-pay before writing code. Document the use case in `design-docs/cloud-storage-discovery.md`.
2. **Schema extension.** Add the following to `schema.sql`: - `module_records` (id, client_id, location_id, module, record_type, record_date, payload_json, version, created_at, created_by, archived) - `module_attachments` (id, record_id, filename, r2_key, size_bytes, content_type, sha256, uploaded_at) - `audit_log` (id, client_id, actor, action, target, at)
3. **Worker endpoints.** Add `/portal/api/records/*` and `/portal/api/attachments/*` following the pattern of `worker/portal.js`. Generic across modules; the `module` column distinguishes them.
4. **R2 bucket provisioning.** One bucket per environment (`radiant-records-prod` , `radiant-records-staging`). Lifecycle rule: transition objects untouched > 1 year to Infrequent Access class.
5. **Desktop app sync layer.** Add a background sync worker thread to each module that POSTs new/changed records to the API and pulls remote changes on app launch. Reuse the local SQLite file as the staging buffer.
6. **Web read/restore UI.** Build a minimal web UI under `/app/cloud/<module>/` that lists records, downloads attachments, and (optionally) renders read-only views. Editing stays in the desktop app.
7. **Pricing & billing.** Sell as \$X/site/month add-on. Use Stripe Billing (or Paddle for VAT/MOSS coverage in international sales). Pricing TBD; benchmark against Microsoft 365 Business per-user pricing (\$6–

\$22/user/month) as the customer's mental anchor.

8. **Pilot with 1–2 customers** for 90 days before general availability.

6.4 Cost model

6.4.1 Per-customer cost to Radiant

Assume a busy clinical site generates:

- ~250 daily QA records/year (1 per business day, ~5 KB JSON each) = ~1.3 MB/year
- ~12 monthly QA records/year (~50 KB each with structure + small attachments) = ~600 KB/year
- ~2 annual QA records/year (~5 MB each with PDFs, screenshots) = ~10 MB/year
- ~50 ad-hoc records (commissioning, special procedure, etc., ~2 MB avg) = ~100 MB/year

Per-site annual data growth: ~110 MB.

RESOURCE	FREE TIER	COST ABOVE FREE TIER	1 SITE COST	100 SITES COST
D1 storage	5 GB	\$0.75/GB-mo	\$0	\$0 (still under 5 GB)
D1 reads	5M/day	\$0.001/M	\$0	\$0
D1 writes	100K/day	\$1/M	\$0	\$0
R2 storage	10 GB	\$0.015/GB-mo	\$0	~\$2/mo (90 GB)
R2 Class A ops (PUT/POST)	1M/mo	\$4.50/M	\$0	\$0
R2 Class B ops (GET/HEAD)	10M/mo	\$0.36/M	\$0	\$0
R2 egress	unlimited free	\$0	\$0	\$0
Workers requests	100K/day	\$0.30/M (after \$5 plan)	\$0	\$5/mo (Workers Paid plan)

Total infrastructure cost at 100 paying cloud-tier sites: ~\$10/month.

This is the single most important number in this proposal. **Cloudflare's no-egress R2 + cheap D1 means the cloud add-on has near-zero marginal cost.** Every dollar charged to a customer for cloud is essentially margin (after one-time dev cost).

6.4.2 One-time build cost

ITEM	ESTIMATE
D1 schema + Worker API endpoints	2–3 weeks
Desktop sync layer (shared library used by all modules)	3–4 weeks
Web read/restore UI	2–3 weeks
Stripe billing integration + customer self-serve	1–2 weeks
Compliance docs (security overview, DPA, data flow)	1 week
Beta with 1–2 customers	90 days calendar (mostly waiting)
Total dev time	~10–13 weeks

6.4.3 Pricing recommendation

- **Hosted backup tier:** \$25/site/month — daily backup, no multi-site rollup, 1-year retention.
- **Multi-site rollup tier:** \$75/site/month — adds cross-site reporting, 7-year retention, audit trail.
- **At 20 sites on the rollup tier:** \$18K/year revenue against ~\$120/year COGS. Margin: 99%.

6.5 Pros — detailed

- **Cost structure is asymmetric in Radiant's favor.** Customers value cloud backup at \$25–\$75/site/month; it costs Radiant pennies. This is the highest-margin product line in the suite by an order of magnitude.
- **Stickiness.** Once a clinic's 7 years of QA records live in Radiant's cloud, switching costs become real. This is the strongest retention mechanism Radiant can build.
- **Multi-site is genuinely valuable.** Consulting physicists covering 5 sites currently log into 5 different file shares. A single web pane that aggregates all of them is a product *they would actually pay for*.
- **Audit trail by default.** D1 makes "who recorded what when" a free side effect. Useful for accreditation surveys.
- **Backup story.** Eliminates the "what if our file server dies before the annual survey?" risk. Sellable on fear alone.
- **Expansion vector.** Enables features impossible in pure desktop: cross-site benchmarking, anomaly detection ("your output factor is 1.5 σ off the suite-wide mean"), aggregate research.

6.6 Cons — detailed

- **Data custody liability.** Once cloud is live, Radiant is *holding customer data*. Breach notification laws apply. Even without PHI, state data-breach statutes (e.g., NYDFS, CCPA) attach to "personal information" which can include employee names in audit logs.
- **Compliance scope grows.** Customers will request: SOC 2 Type II report (~\$30K–\$80K/year), penetration test reports (~\$10K/year), security questionnaires (free but time-consuming), a written DPA. None of these are required to *start*, but they become deal-blockers as Radiant moves upmarket.
- **Cloudflare BAA is Enterprise-only.** If a future customer wants to store PHI-adjacent data and demands a BAA, Cloudflare's price jumps from ~\$10/month to ~\$2K+/month. Stated mitigation:

refuse to store PHI in the standard tier, document clearly, redirect such customers to a future BAA tier (see §7 — Phase 4: HIPAA-compliant cloud tier) or to AWS-backed alternative (see §8.2).

- **Ops burden.** On-call for the API. Monitoring. Backup verification. Status page. Incident response runbook. None of these exist today.
- **Subscription billing complexity.** Stripe is easy; dunning, proration, mid-cycle plan changes, tax compliance across states is not. Recommend Paddle as MoR if international sales are expected (handles VAT, MOSS, sales tax).
- **Downtime impact.** When the desktop runs offline-first, a Cloudflare outage is invisible. When cloud sync is live, a Cloudflare outage means customers see "sync failed" toasts — and they will call. Cloudflare's SLA is good but not perfect.
- **Schema migrations across all desktop versions.** Once 100 clinics are running QuikQA 2.3.1 with one schema and the cloud expects 2.4.0's schema, every desktop release must be backward/forward compatible. This is a real engineering tax. Mitigated by JSON payloads with schema versions inside.
- **Conflict resolution edge cases.** Two physicists editing the same record from two laptops will occasionally collide. Last-write-wins is correct 95% of the time; the other 5% generates support tickets.
- **Customer education.** "Where is my data, who can see it, can you delete it, can I export it" — every cloud customer asks. Need a one-page data-handling document and an export-everything button.

7. Phase 4 — HIPAA-compliant cloud tier (future evolution)

7.1 What Phase 4 means and how it differs from Phase 3

Phase 3 (§6) was designed around a deliberate constraint: **no PHI**. By restricting the cloud tier to QA metrology data, Radiant stays on Cloudflare's standard pricing tier, avoids the Enterprise-only BAA requirement, and side-steps the HIPAA compliance scope entirely. That makes Phase 3 cheap, fast, and low-risk — but it caps the addressable cloud-tier market to customers whose use case doesn't require PHI handling.

Phase 4 lifts that cap. It introduces a separate, premium cloud tier specifically for clients who need to store data that qualifies as Protected Health Information under HIPAA — for example, patient-identified treatment records in QuikLog, patient-attached bolus designs in QuikBolus, patient-specific dosimetry records in QuikDose, or treatment-plan-linked documentation in QuikCare.

This is **not** an incremental feature on top of Phase 3. It is a parallel premium tier with its own infrastructure, vendor relationships, compliance scope, pricing, and contractual framework. The economic argument for building it rests almost entirely on customer demand at scale — the fixed compliance overhead is large enough that small-volume operation loses money.

7.2 Trigger conditions

Do not begin Phase 4 build work until **all** of the following are true:

1. Phase 3 cloud tier has at least **5 paying customers** generating recurring revenue.
2. At least **2 prospective customers** have explicitly identified HIPAA compliance as a blocker to their purchase, with a stated willingness to pay materially more for it.

3. Radiant's overall ARR is **≥ \$500K/year**, providing cash cushion to absorb the compliance overhead without putting the business at risk.
4. Founder availability supports a 6–12 month focused effort, or contract dev help is secured for the duration.

Realistic decision point: **late 2028 to early 2029**, after the Phase 2 desktop suite is mature and Phase 3 cloud is generating revenue.

7.3 Vendor evaluation

Three serious candidates exist. Each is HIPAA-eligible with BAA included, and each represents a different trade-off between operational burden and per-unit cost.

Option A — AWS with BAA

- HIPAA-eligible services available on standard pricing: S3, RDS, DynamoDB, Lambda, API Gateway, CloudFront, KMS, EC2, ECS, SES, and more.
- BAA included at no additional charge; sign in AWS Artifact.
- Most flexible architecture; widest healthcare-SaaS ecosystem.
- Steepest operational learning curve: VPCs, IAM, security groups, KMS, parameter store, CloudWatch, GuardDuty all require setup and maintenance.
- Best long-term economics at >\$300K/yr cloud-tier revenue.

Option B — Aptible

- HIPAA-compliant Platform-as-a-Service — purpose-built for healthcare startups.
- Encryption at rest, encryption in transit, audit logging, access controls, and HIPAA-conformant logging all baked into the platform.
- BAA included.
- Platform fee: ~\$1,500/month starter, scaling to ~\$3,500–\$5,000/month at moderate scale.
- Compresses compliance setup time from ~6 months to ~6 weeks.
- Less flexible than raw AWS; some advanced workloads aren't supported.
- Best for bootstrapping the first 1–2 years of Phase 4.

Option C — Microsoft Azure

- Comparable to AWS in BAA terms and service breadth.
- Strong story when the customer is a Microsoft-stack hospital (Active Directory, M365, Power BI integration).
- Same operational burden as AWS.
- Recommend only if a specific prospect makes Azure a procurement requirement.

Other vendors briefly considered: Google Cloud Platform (HIPAA-eligible, comparable to AWS/Azure, but smaller medical-SaaS ecosystem); MedStack (Canadian healthcare PaaS, similar to Aptible); Datica Health, TrueVault, HIPAA Vault (managed compliance hosting, typically 2–4× the cost of Aptible for similar functionality). None of these change the recommendation.

Recommended path: Launch Phase 4 on **Aptible**. Migrate to **AWS** once Phase 4 ARR exceeds ~\$300K/year and the unit-economics math favors absorbing the operational lift in exchange for lower per-client infrastructure cost.

7.4 Compliance scope beyond hosting

A signed BAA with the cloud vendor is necessary but not sufficient. True HIPAA compliance requires a full program:

1. **Bidirectional BAAs.** Radiant signs the cloud vendor's BAA; Radiant signs *its own* BAA template with each customer that stores PHI.
2. **Subprocessor BAAs.** Every vendor that touches the data path needs a signed BAA: email provider (Postmark, AWS SES), monitoring (Datadog HIPAA tier), payment processor (Stripe Healthcare), error tracking, etc.
3. **Encryption.** AES-256 at rest with customer-managed keys (KMS); TLS 1.2+ in transit; strict cipher suites.
4. **Access controls.** Multi-factor authentication for all administrative access. Least-privilege IAM. No shared accounts.
5. **Audit logging.** Every access to PHI logged with actor, timestamp, action, target. Retention: 6 years minimum.
6. **Risk assessment.** Annual third-party HIPAA risk assessment; documented gap remediation.
7. **Policies and procedures.** Written information security policy, privacy policy, access management, incident response, breach notification, sanctions, workforce training. ~30–50 pages of documentation.
8. **Workforce training.** Annual HIPAA training for everyone with access (initially Todd; later any contractors or staff).
9. **Incident response plan.** 60-day breach notification capacity, documented procedures, tested annually.
10. **Designated officers.** Privacy Officer and Security Officer (single founder can hold both roles at small scale).
11. **Vendor risk management.** Annual review of every subprocessor.
12. **Penetration testing.** Annual independent pen test; required by most cloud vendor BAAs.
13. **Optional but increasingly required:** SOC 2 Type II report. Not strictly a HIPAA requirement, but hospital procurement teams increasingly demand it. Adds substantial cost; defer until 5+ HIPAA customers exist.

7.5 Cost structure

7.5.1 Annual fixed compliance overhead

These costs are largely independent of client count. They are the cost of being HIPAA-compliant at all:

LINE ITEM	ANNUAL COST (RANGE)
Legal — HIPAA-aware attorney (BAAs, customer DPA, terms)	\$8,000
Third-party HIPAA risk assessment	\$5,000
Annual penetration test	\$15,000
HIPAA training platform (Compliancy Group, HIPAA Vault, etc.)	\$2,000
Cyber liability insurance with HIPAA breach coverage	\$5,000–\$15,000
Compliance tooling (SIEM, vulnerability scanning, log aggregation)	\$10,000
Platform compliance overhead (Aptible base fee, or AWS compliance tools)	\$20,000–\$40,000
Designated Privacy/Security Officer (fractional; founder-borne at small scale)	\$0–\$50,000
Optional SOC 2 Type II audit (when added)	\$25,000–\$50,000
Annual fixed compliance overhead	~\$70,000–\$200,000

Lower end: founder wears compliance hats, no SOC 2 yet, lean tooling, small cyber insurance. Upper end: fractional compliance staff, SOC 2 Type II in place, enterprise tooling.

7.5.2 Variable infrastructure cost per client

Realistic data growth profile assuming the client uses **all 15 modules** at a representative scale (3 linacs, 4 physicists, full-service clinical workflow):

MODULE	ANNUAL DATA GROWTH
QuikQA (3 linacs × daily/monthly/annual)	~40 MB/yr
QuikLog (3 linacs × machine logs)	~300 MB/yr
QuikCalc + QuikDose + QuikScript (per-case)	~30 MB/yr
QuikRef (read-only mostly)	<10 MB/yr
QuikBolus (STL files, ~50 bolus/yr × 20 MB)	~1 GB/yr
QuikShield (occasional calc artifacts)	~100 MB/yr
QuikRAM (lightweight inventory + receipts)	~50 MB/yr
QuikCare (workflow + attachments)	~100 MB/yr
QuikShare (file passthrough, transient)	~5 GB/yr
Business modules combined	~200 MB/yr
Total new data per client per year	~7 GB/yr
Mature client at 7-yr retention	~50–70 GB stored

Per-client cloud infrastructure cost at maturity:

RESOURCE	AWS PATH	APTIBLE PATH
Storage (50 GB, Standard-IA-equivalent)	~\$10/yr	included in app allocation
Compute (API + sync workers)	~\$200/yr	~\$800/yr (dyno share)
Egress (10 GB/mo)	~\$10/yr	included
KMS, CloudWatch, GuardDuty	~\$50/yr	included
Backup + DR storage	~\$30/yr	~\$200/yr
Audit logging long-term retention	~\$50/yr	included
Variable cost per client per year	~\$350	~\$1,000–\$1,300

Aptible looks more expensive per-client but eliminates ~\$30–\$50K/yr in setup and ongoing compliance tooling. The break-even between paths is around 25–30 clients.

7.5.3 Projections by client tier (all 15 modules per client)

Aptible path (recommended for first 1–2 years):

CLIENTS	FIXED COMPLIANCE	VARIABLE INFRA	TOTAL ANNUAL COST	REVENUE AT 60% MARGIN	PER-CLIENT CLOUD PRICE IMPLIED
2	\$70,000	\$2,500	\$72,500	\$181,250	\$90,600/yr
5	\$80,000	\$6,500	\$86,500	\$216,250	\$43,250/yr
10	\$90,000	\$13,000	\$103,000	\$257,500	\$25,750/yr
15	\$100,000	\$20,000	\$120,000	\$300,000	\$20,000/yr
25	\$110,000	\$33,000	\$143,000	\$357,500	\$14,300/yr
50	\$145,000	\$65,000	\$210,000	\$525,000	\$10,500/yr

AWS path (after migration, year 2+):

CLIENTS	FIXED COMPLIANCE	VARIABLE INFRA	TOTAL ANNUAL COST	REVENUE AT 60% MARGIN	PER-CLIENT CLOUD PRICE IMPLIED
2	\$90,000	\$700	\$90,700	\$226,750	\$113,400/yr
5	\$100,000	\$1,750	\$101,750	\$254,400	\$50,900/yr
10	\$115,000	\$3,500	\$118,500	\$296,250	\$29,600/yr
15	\$125,000	\$5,250	\$130,250	\$325,600	\$21,700/yr
25	\$145,000	\$8,750	\$153,750	\$384,400	\$15,400/yr
50	\$180,000	\$17,500	\$197,500	\$493,750	\$9,900/yr

Critical insight: AWS has higher fixed cost (compliance tooling, ops burden) but materially lower variable cost. Below 15 clients, Aptible is cheaper per client. Above 25 clients, AWS becomes meaningfully cheaper and the migration math starts to pay off.

7.5.4 The break-even reality

The numbers above expose the hard truth of HIPAA SaaS at small scale:

- **At 2 HIPAA clients**, you would need to charge ~\$90K/year each. That is essentially unsellable to anyone but a major enterprise customer with budget authority and an unmet need.
- **At 5 clients**, \$43K/year per client is at the high end of clinical software pricing but defensible for a fully-integrated HIPAA-compliant suite.
- **At 10–15 clients**, \$20–\$26K/year per client lands in line with market expectations for premium clinical SaaS.
- **At 25–50 clients**, \$10–\$15K/year is highly competitive and generates strong margin contribution.

The HIPAA tier is **structurally unprofitable below ~10 paying customers**. This is a defining business reality of healthcare compliance: the fixed overhead is too large to amortize across small client counts. Either Radiant commits to a scale-out path with confidence in customer demand, or it does not enter the market.

7.6 Pricing recommendation

Based on the per-tier math, recommend a tiered pricing approach that signals scale-readiness without overcommitting:

TIER	LAUNCH PRICE (≤5 CUSTOMERS)	MATURE PRICE (25+ CUSTOMERS)
HIPAA Cloud — Single Site	\$24,000/site/yr	\$14,000/site/yr
HIPAA Cloud — Multi-Site Rollup	+\$3,000/additional site	+\$2,000/additional site
BAA-only (no rollup features)	\$18,000/site/yr	\$10,000/site/yr

This is the **cloud add-on price**, layered on top of the standard module subscriptions (which still apply at desktop pricing). A HIPAA customer's total ARR is therefore: per-module licensing + HIPAA cloud tier.

7.7 Time to launch

Aptible path (recommended for first wave):

STAGE	DURATION
Vendor evaluation, BAA negotiation, account provisioning	4–6 weeks
Compliance documentation (policies, procedures, IR plan)	8–12 weeks (with legal review in parallel)
Application deployment to Aptible + integration testing	8–12 weeks
Internal training, audit-logging validation, IR drill	4–6 weeks
Annual pen test + gap remediation	6–8 weeks
Total time to general availability (Aptible)	~6–9 months

AWS path (longer; recommend only after Aptible track record exists):

- Add 3–6 months for AWS infrastructure setup, IAM design, KMS key hierarchy, VPC architecture, observability stack.

- **Total time to GA on AWS from scratch: ~9–15 months.**

If pursuing SOC 2 Type II (recommended for hospital sales beyond the first 5 customers):

- Add 6 months of operating-evidence window before audit can begin.
- Audit itself: 2–3 months.
- **Total time including SOC 2: 12–18 months.**

7.8 Pros — detailed

- **Unlocks the upper end of the market.** Academic medical centers, IDNs, and any prospect with PHI in scope will not engage Phase 3 (non-HIPAA) cloud at all. Phase 4 is the gate to that customer segment.
- **Premium pricing power.** HIPAA-compliant clinical SaaS commands 5–10× the per-customer revenue of non-PHI tools at the same data volume. Margin contribution at scale is significant.
- **Competitive moat.** Most physics-software competitors do not offer HIPAA-compliant cloud storage. Being one of the few with a defensible BAA story is a sales differentiator.
- **Foundation for higher-value features.** Once PHI handling exists, downstream products become possible — cross-site treatment-outcome analysis, AI-assisted plan review, audit-trail-for-accreditation packages — each with its own premium pricing.
- **Retention via switching cost.** HIPAA cloud customers, once integrated, are essentially impossible to migrate away from. Customer lifetime value approaches infinity.

7.9 Cons — detailed

- **Large fixed overhead before any revenue.** \$70–\$100K in compliance costs are committed before the first HIPAA customer signs. This is real capital at risk if demand doesn't materialize.
- **Operational discipline becomes mandatory.** "Move fast and break things" is incompatible with HIPAA. Every code change touching PHI needs a security review. Every deploy needs change management. Every incident needs documented response. This is a cultural shift, not just an engineering shift.
- **Liability exposure scales with customer count.** A breach affecting 50 HIPAA customers is reportable to HHS, can trigger civil penalties up to \$1.9M/year per violation category, and is reputationally devastating. Cyber insurance helps but doesn't eliminate the exposure.
- **Solo-founder bus factor becomes unacceptable.** HIPAA explicitly requires a designated Security Officer and Privacy Officer; if Todd is incapacitated, the program is in violation. Contract dev help isn't sufficient — Phase 4 likely requires hiring at least one full-time team member.
- **Sales cycle lengthens.** Hospital security reviews for HIPAA SaaS routinely take 4–9 months. Procurement asks for SOC 2 reports, pen test summaries, BAAs, DPIAs, subprocessor lists, breach notification SLAs. Expect deal velocity to slow even as deal sizes grow.
- **Customer support burden grows.** HIPAA customers ask harder questions, demand faster response times, and expect formal incident communications. Expect 2–3× per-customer support cost vs Phase 3 customers.
- **Compliance is recurring, not one-time.** Annual risk assessments, pen tests, training, policy reviews. The \$70K+ overhead is permanent, not amortizable.
- **Migration path complications.** Moving an existing Phase 3 cloud customer onto Phase 4 requires re-signing, re-onboarding, sometimes re-architecting their data path. Plan for migration friction.

- **Cloud vendor concentration risk.** A BAA termination by Aptible or AWS (rare but possible if Radiant violates terms) would be an existential event. Mitigate by documenting cloud-portable architecture from day one.

7.10 Integration with existing phases

Phase 4 sits *alongside* Phase 3, not replacing it. The deployed shape becomes:

- **Free tier** (Phase 1, web sandbox): unchanged. Trial only, no data persistence beyond browser.
- **Desktop tier** (Phase 2): unchanged. Customer keeps data locally. Default for most clinical customers.
- **Phase 3 cloud (standard tier):** unchanged. No PHI. Cheap, fast, high-margin. For customers wanting backup + multi-site rollup without PHI in scope.
- **Phase 4 cloud (HIPAA tier):** new. PHI-permitted. Premium pricing. For customers whose use case genuinely requires PHI handling.

Customers should be steered toward the lowest tier that meets their actual needs. The HIPAA tier is not the default and should not be marketed as a default — only as an option for the use cases that demand it.

8. Alternatives considered (and not recommended)

8.1 Full cloud-only, no desktop channel

What it means: Skip Phase 2 entirely. Build every module as a web app on Cloudflare. Sell SaaS-style at \$X/site/month.

Pros: - Single delivery channel — no installer maintenance, no per-platform builds, no patch zips. - Instant updates for everyone simultaneously. - Full telemetry from day one. - Strongest possible product analytics → faster iteration.

Cons: - Hospital procurement is hostile to cloud. Sales cycle stretches 3–6× longer. - Loses the offline / isolated-VLAN segment of the market entirely. That's a meaningful chunk of community-hospital and proton-center physicists. - All compliance scope (SOC 2, breach notification, DPA) becomes day-one mandatory, not deferred. - Radiant becomes a data-custodian for every customer from day one. No opt-out. - Browser-based clinical tools have an uphill battle for trust against established desktop competitors.

Verdict: This is the riskiest path. It maximizes time-to-revenue per deal and minimizes total addressable market. Reject.

8.2 Migrate the platform to AWS

What it means: Move the Worker + D1 + R2 stack to AWS Lambda + RDS/DynamoDB + S3.

Pros: - BAA available on standard pricing (not Enterprise-only as with Cloudflare). Enables PHI-adjacent products later. - "We're on AWS" is universally recognized by hospital IT. - Massive service catalog if Radiant ever needs ML/imaging (SageMaker, Rekognition, HealthLake). - S3 Glacier Deep Archive at \$1/TB-month is unbeatable for 7+ year cold retention. - Mature observability tools (CloudWatch, X-Ray, Cost Explorer).

Cons: - **Egress costs.** AWS charges \$0.09/GB out; Cloudflare R2 is free. Every customer download is a cost line. - **Ops complexity.** VPCs, IAM, security groups, parameter store, KMS. Solo-developer time sink. -

Latency. Lambda regional cold-start (~150–300ms) vs Workers edge (~50ms). Customers feel it. - **Cost at small scale.** AWS minimums (NAT gateway alone is ~\$32/mo before any traffic) dwarf Cloudflare's ~\$5/mo plan. - **Migration cost.** All existing code (`worker/index.js` , `worker/clients.js` , `worker/portal.js` , `worker/admin-auth.js` , `worker/license-core.js`) would need to be rewritten for the Lambda runtime. Weeks of work for no customer-visible benefit.

Verdict: Reject for now. Revisit only if (a) a paying customer makes "AWS-hosted" a procurement requirement, or (b) Radiant launches a PHI-handling product that needs a standard-tier BAA.

8.3 Self-hosted server appliance shipped to the clinic

What it means: Sell a small Linux box (or VM image) that runs the cloud-tier services on the clinic's LAN.

Pros: - Clinic's data never leaves their network. Strongest privacy story. - No internet dependency. - Sellable to the most paranoid customers.

Cons: - Radiant becomes a hardware vendor or VM-image maintainer. New skill set. - Update channel for the appliance is harder than for a Worker. - Customer IT has to maintain it (backups, OS patches, certs). - High support burden per customer.

Verdict: Reject for Phase 3. Reconsider only as a *premium* tier (\$300+/site/month) for customers who explicitly demand on-prem.

9. Risk register

RISK	LIKELIHOOD	IMPACT	MITIGATION
Customer wipes browser data during trial, loses work, churns	Medium	Low	Export-to-JSON button on every demo; trial copy warns clearly
Desktop installer flagged by Windows SmartScreen / antivirus	High initially	Medium	OV code-signing cert; submit binaries to MS/Symantec/etc.
Hospital IT refuses to install unsigned MSI	High	High	Code-signing cert in Phase 2 budget
Cloudflare D1 service deprecation or pricing change	Low	High	Schema is portable SQL; can lift-and-shift to Postgres anywhere in <2 weeks
Cloud-tier customer demands BAA	Medium (over 3 years)	High if needed	Document non-PHI policy upfront; escalation path is AWS-backed BAA tier
Data breach in cloud tier	Low	Very high	Encryption at rest (default in D1/R2); strong session auth (already exists); paid pen test before GA; cyber insurance (\$1–3K/yr at startup scale)
Sync conflicts confuse customers	Medium	Low	Version history UI; "last edit wins" with audit trail
One developer (current state) is a bus factor	High	Critical	Document everything; consider a contract dev for Phase 2 module packaging; treat the worker/D1 layer as the most-documented part of the codebase
Competitor (Doselab/RIT/SunCheck) drops desktop prices to commoditize	Medium	Medium	Compete on price + integration breadth (full suite vs single-product competitors)
Phase 4 fixed compliance overhead committed before customers sign	Medium (if Phase 4 starts)	High	Hard trigger criteria in §11.2; do not enter HIPAA market on speculation
HIPAA breach in Phase 4 tier	Low	Existential	Aptible/AWS BAA; encryption + KMS; annual pen test; cyber insurance with HIPAA rider; documented IR plan; SOC 2 Type II by year 2
Aptible/AWS BAA termination for compliance violation	Very low	Existential	Maintain compliance program; portable architecture documented from day one; quarterly internal compliance review
Hospital procurement requires SOC 2 Type II before Phase 4 customer signs	High (>20% of HIPAA prospects)	Medium	Plan SOC 2 audit window concurrent with first 5 HIPAA customers; budget \$25–50K

RISK	LIKELIHOOD	IMPACT	MITIGATION
Founder unavailable when designated Privacy/Security Officer role required	Medium	Existential in Phase 4	Hire compliance-capable team member before Phase 4 GA (in §11.2 trigger criteria)

10. Recommended timeline

2026 Q3	Phase 1: Web app reposition; trial flow; banner copy
	Migrate QuikCalc, QuikRef, QuikScript, QuikDose calc to launcher
2026 Q4	Phase 2 begins: QuikQA installer to GA
	Code-signing cert procurement
2027 Q1	QuikBolus + QuikCalc + QuikDose desktop GA
2027 Q2	QuikRAM + QuikShield + QuikScript + QuikRef GA
2027 Q3	Remaining modules GA; full suite shipping as desktop
	Cloud discovery interviews (3+ paying-customer conversations)
2027 Q4	Phase 3 build if discovery confirms demand
2028 Q1	Phase 3 cloud beta with 1-2 customers
2028 Q2	Phase 3 cloud GA; pricing live; marketing push
2028 Q3	Phase 4 (HIPAA) discovery: identify 2+ paying customers asking for BAA
2028 Q4	Phase 4 decision point: go/no-go based on §11 criteria
	If go: Aptible BAA + vendor evaluation; first hire (compliance-capable)
2029 Q1	Phase 4 compliance docs + policies + IR plan drafted; legal review
	Application deployment to Aptible begins
2029 Q2	Phase 4 internal training, audit-log validation, IR drill
	Annual pen test #1
2029 Q3	Phase 4 GA with first 2 HIPAA customers (premium-priced launch)
	SOC 2 Type II operating-evidence window begins
2030 Q1	Phase 4 expansion: 5-10 HIPAA customers
2030 Q2	SOC 2 Type II audit window opens; first report by mid-year
2030 Q4	Evaluate AWS migration path (trigger: \$300K+/yr Phase 4 ARR)

This is intentionally conservative. The desktop channel (Phase 2) is where most revenue lives; Phase 3 is high-margin upside; Phase 4 is a deliberate, capital-disciplined expansion into the enterprise/PHI segment of the market.

11. Decision criteria for triggering Phase 3 and Phase 4

11.1 Phase 3 (non-PHI cloud) triggers

Do not start Phase 3 build work until **all** of the following are true:

1. At least 5 paying customers on the Phase 2 desktop product.
2. At least 2 of them have asked, unprompted, for some form of centralized storage, backup, or multi-site access.
3. At least 1 of them has stated a willingness-to-pay in the \$25/site/month range or higher.

4. Phase 2 module-shipping pipeline is stable enough that 10–13 weeks of dev attention can be diverted without stalling the desktop roadmap.

If any of these conditions are not met, defer Phase 3 by another quarter and revisit.

11.2 Phase 4 (HIPAA-compliant cloud) triggers

Phase 4 is a materially larger commitment than Phase 3. Do not start Phase 4 build work until **all** of the following are true:

1. Phase 3 cloud tier has at least **5 paying customers** generating recurring revenue.
2. At least **2 prospective customers** have explicitly identified HIPAA compliance as a blocker to purchase, with a stated willingness to pay at least \$24K/site/yr for the HIPAA tier.
3. Radiant's overall ARR is **≥ \$500K/year** (provides cash cushion for the \$70–\$100K compliance overhead).
4. A compliance-capable hire has been made (or contracted) to share the Privacy/Security Officer load with the founder.
5. Phase 2 + Phase 3 are stable enough that 6–12 months of focused effort can be diverted.

If fewer than 4 of the 5 conditions are met, **do not proceed**. The fixed compliance overhead is too high to absorb on speculation. Defer at least 6 months and reassess.

11.3 AWS migration trigger (within Phase 4)

Migrate the Phase 4 platform from Aptible to AWS only when:

1. Phase 4 ARR exceeds **\$300K/year** (≥15 HIPAA customers at mature pricing).
2. The variable-cost delta between Aptible and AWS exceeds **\$25K/year** at current scale.
3. Engineering capacity exists for a 3–6 month migration without disrupting customer service.

12. Summary of recommendations

1. **Reposition** `app.radiant-mpc.com` as a **demo + trial sandbox**. Add clear copy. Migrate the simpler modules into it. Cost: ~\$0 incremental.
2. **Make the desktop installer the commercial product** for all modules. Reuse existing PyInstaller scaffolding. Add code-signing. Use the existing license manager + revocation endpoint for enforcement.
3. **Defer Phase 3 cloud storage until customer demand is proven**. When triggered, build on Cloudflare D1 + R2 — costs are negligible (~\$10/month for 100 sites), margins are exceptional (>99%).
4. **Treat Phase 4 (HIPAA-compliant cloud) as a deliberate, demand-driven future evolution**. Launch on Aptible to compress time-to-market; migrate to AWS only after Phase 4 ARR exceeds \$300K/yr. Do not enter the HIPAA market with fewer than 10 committed customers — the fixed overhead makes small-scale operation structurally unprofitable.
5. **Reject AWS migration for the standard (Phase 1–3) platform**. Cloudflare is materially better for that workload at small-to-mid scale. AWS becomes relevant only inside the Phase 4 HIPAA tier, and only at scale.
6. **Reject full-cloud-only delivery**. Loses the offline / hospital-IT-friendly segment of the market.

7. **Reject on-prem appliance** for now. Reconsider only as a premium tier later.

The infrastructure Radiant has already built is exceptionally well-suited to this plan. No platform changes required — only sequencing.